Université Mohamed Premier
Ecole Supérieure de Technologie de Nador

Département d'Innovation Technologique et Ingénierie Informatique
Filière d'Ingénierie Logicielle et Cybersécurité

Rapport de Mini-Projet ERP : Sécurisation, audit et amélioration d'un système ERP Odoo

Réalisé par:

Mlle. NORHANE RAMZI

Mr. MOHAMED AYMANE JLIDA

Mr. ZAKARIYA BENYAMNA

Mr. MEHDI BOUDZOUAOU

Mr. ZAKARIYA EL MILOUDY

Mr. WALID HAMROUD

Encadré par :

Mr. Redouane ESBAI, Professeur à l'ESTN

Année universitaire : 2025/2026

Introduction

Dans le cadre du Mini-Projet portant sur la sécurisation, l'audit et l'amélioration d'un système ERP Odoo, le présent dossier constitue le Livrable dédié à l'analyse de l'architecture technique d'Odoo. L'objectif est de comprendre l'organisation interne du système, d'identifier les omposants critiques et d'analyser les flux de données sensibles afin de préparer la démarche de sécurisation.

1.Contexte et objectifs du projet

1.1 Présentation du contexte métier

Dans le cadre de notre formation académique, ce mini-projet porte sur la sécurisation, l'audit et l'amélioration d'un système ERP Odoo. Le contexte étudié est celui d'une PME multiservices utilisant Odoo pour gérer ses ventes, ses ressources humaines, sa facturation ainsi que ses utilisateurs internes.

Suite à plusieurs incidents, notamment des accès non autorisés, des erreurs de manipulation et un manque de traçabilité, il est devenu nécessaire d'analyser le système existant afin d'identifier ses faiblesses de sécurité et de proposer des mesures correctives adaptées.

Ce travail s'inscrit dans une démarche d'ingénierie logicielle et de cybersécurité visant à mieux comprendre l'architecture d'un ERP réel, à renforcer son niveau de sécurité et à améliorer la fiabilité globale du système.

1.2 Objectifs du projet

Notre équipe intervient en qualité d'ingénieurs logiciels et sécurité. Les objectifs sont les suivants :

- Analyser l'architecture générale d'Odoo .
- Identifier les composants critiques et les flux de données sensibles .
- Mettre en place une gestion rigoureuse des utilisateurs et des droits d'accès selon le modèle RBAC .
- Analyser les risques et vulnérabilités du système .
- Appliquer des mesures de sécurisation adaptées.
- Améliorer la traçabilité des actions utilisateurs .
- Proposer des améliorations logicielles cohérentes avec les besoins du système.

À travers ce travail, l'objectif est de produire un environnement Odoo mieux sécurisé, documenté et plus conforme aux bonnes pratiques de cybersécurité.

1.3 Périmètre du travail

Le travail pratique a été réalisé sur une instance Odoo configurée pour les besoins du mini-projet. L’étude s’est concentrée principalement sur les modules suivants :

- Utilisateurs et droits d’accès
- Ventes
- Facturation .
- Ressources humaines .
- Logs et audit.

Le projet ne vise pas à couvrir tout l’écosystème Odoo, mais à se concentrer sur les éléments les plus sensibles du point de vue de la sécurité, de la traçabilité et de la qualité logicielle.

1. ANALYSE DE L'ARCHITECTURE ODOO

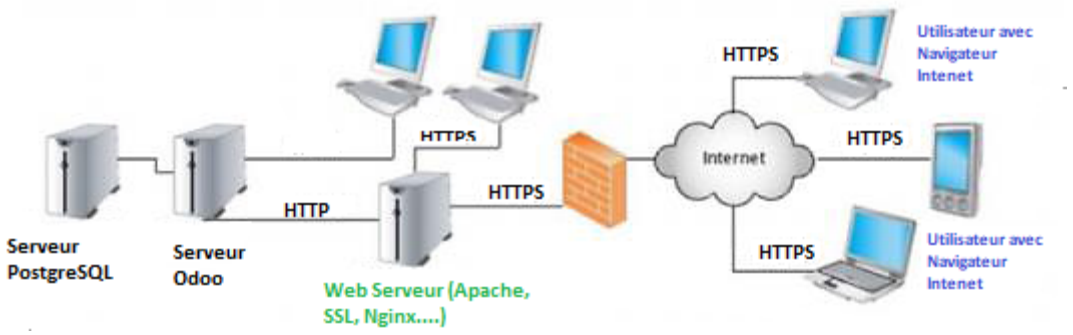
1.1 Architecture générale d'Odoo

Odoo repose sur une architecture trois-tiers classique composée d'une couche présentation, d'une couche applicative et d'une couche persistance.

La couche présentation est assurée par un navigateur web (Chrome, Firefox) qui communique avec le serveur via le protocole HTTP sur le port 8069. L'interface utilisateur est rendue dynamiquement grâce au framework JavaScript OWL (Odoo Web Library).

La couche Métier est le cœur du système. Elle est développée en Python et repose sur le framework Odoo, qui intègre un ORM (Object-Relational Mapper) permettant d'abstraire les opérations sur la base de données. C'est à ce niveau que sont gérés les modules métier : Ventes, Ressources Humaines, Facturation, etc.

La couche persistance est assurée par PostgreSQL, le SGBD relationnel open-source sur lequel Odoo stocke l'ensemble des données métier. Chaque modèle Odoo correspond à une table PostgreSQL.



1.2 Composants critiques identifiés

L'analyse de notre instance Odoo Community [version X.X] a permis d'identifier les composants critiques suivants :

- **Module d'authentification (res.users) :** gère les identifiants et sessions de tous les utilisateurs. Toute compromission de ce module donne un accès total au système.
- **API XML-RPC / JSON-RPC :** interfaces de programmation exposées par défaut sur /xmlrpc/2 et /web/dataset/call_kw. Elles permettent un accès programmatique à toutes les données sans interface graphique.
- **Module Facturation (account.move) :** contient toutes les données financières (factures, paiements, avoirs). Accès à restreindre strictement.
- **Module RH (hr.employee) :** contient les données personnelles et contractuelles des employés. Soumis aux exigences du RGPD.
- **Base de données PostgreSQL :** contient l'intégralité des données en clair. Un accès direct au SGBD contourne tous les contrôles applicatifs.

Nom	Modèle	Groupe	Accès en lecture	Accès en écriture	Droit de création	Droit de suppression
res.users.settings	Paramètres utilisateur	Rôle / Utilisateur	☑	☑	☑	☑
res.users.settings	Paramètres utilisateur		☐	☐	☐	☐
res.users.settings.embedded.action	Paramètres utilisateur ...	Rôle / Utilisateur	☑	☑	☑	☑
res.users.settings.volumes	Volumes des paramètr...	Rôle / Utilisateur	☑	☑	☑	☑

1.3 Flux de données sensibles

Trois principaux flux de données sensibles ont été identifiés dans le système. Le premier concerne les données financières, qui circulent entre les modules de vente et de facturation. Le deuxième concerne les données personnelles des employés, gérées dans les modules liés aux ressources humaines. Le troisième flux concerne les identifiants et les sessions utilisateurs, stockés dans les modèles de gestion des comptes.

Ces flux sont critiques car ils transportent des informations confidentielles qui doivent être protégées contre les accès non autorisés, les erreurs de manipulation et les modifications malveillantes. Leur analyse permet de mieux comprendre les points de vulnérabilité du système et de préparer les étapes suivantes du mini-projet, notamment la mise en place du RBAC et l’analyse des risques.

1.4 Diagrammes UML

Diagramme de classe :

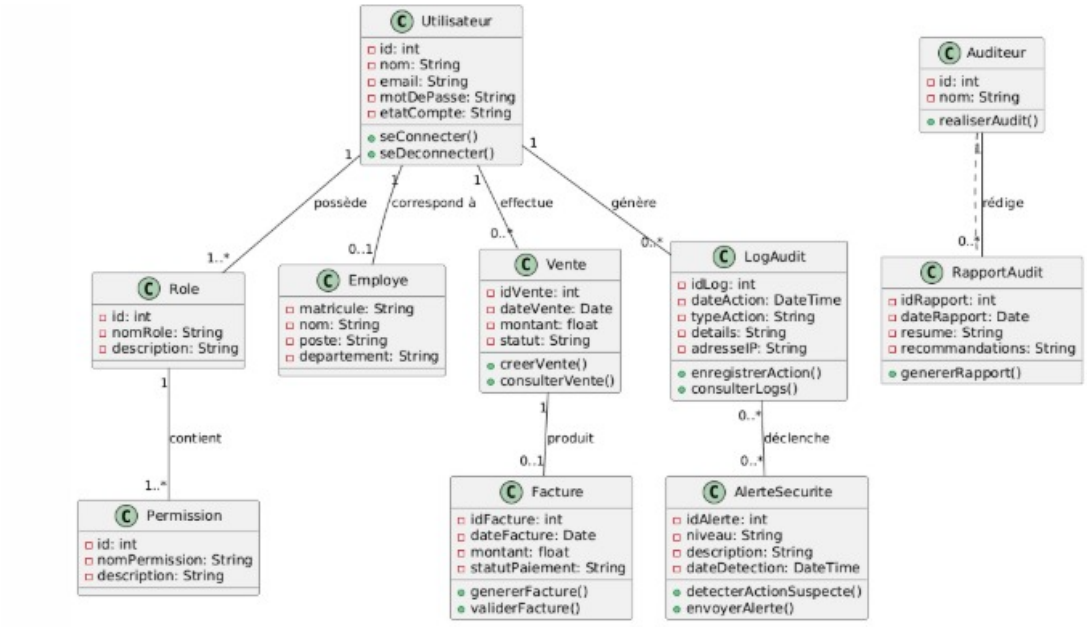


Diagram de Déploiement :

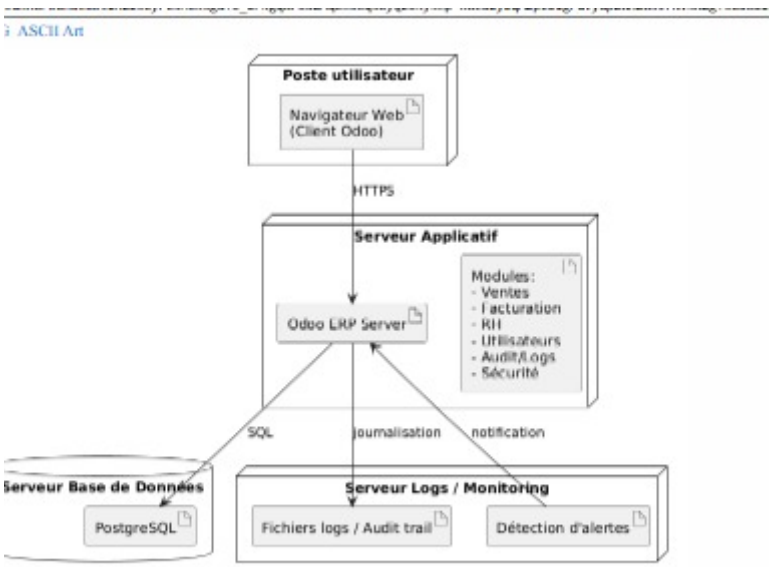
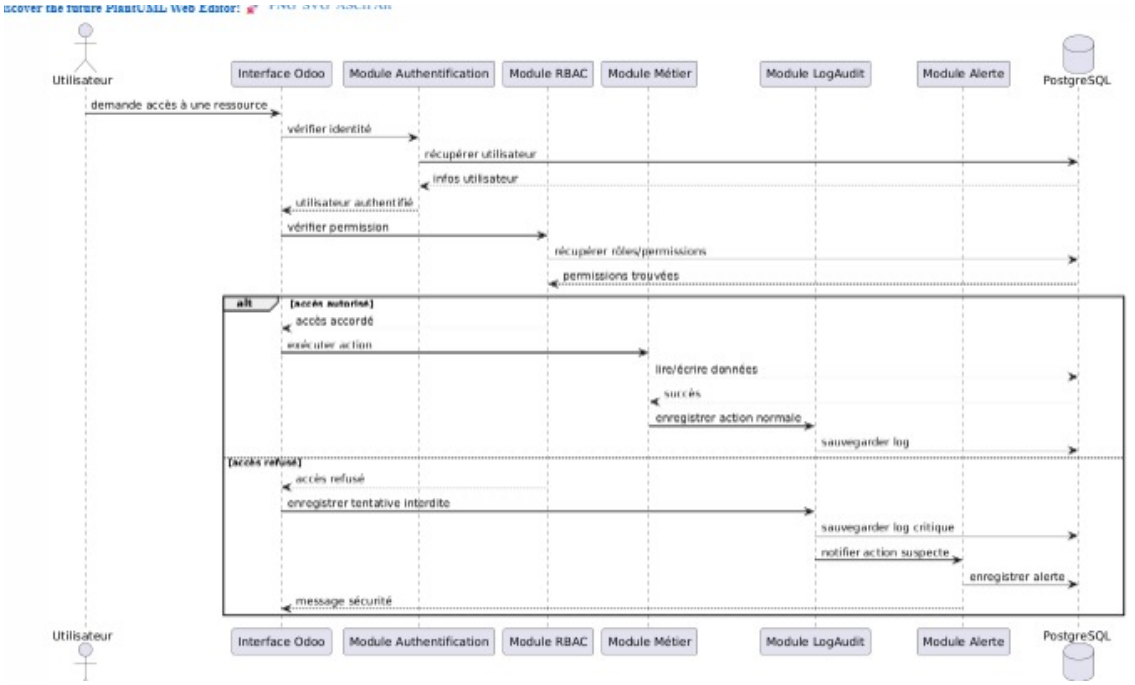


Diagramme de séquence



2 . Gestion des utilisateurs et des rôles (RBAC)

2.1 Principe du moindre privilège

Le contrôle d’accès basé sur les rôles, ou RBAC, consiste à attribuer des permissions aux utilisateurs selon leur fonction dans l’organisation. Cette approche repose sur le principe du moindre privilège, selon lequel chaque utilisateur ne doit disposer que des droits strictement nécessaires à l’exécution de ses tâches. Dans notre mini-projet, cette logique a été appliquée afin de limiter les accès excessifs et de mieux protéger les données sensibles de l’ERP.

2.2 Profils utilisateurs créés

Quatre profils utilisateurs ont été configurés dans l’instance Odoo, conformément au sujet du mini-projet : Administrateur, Responsable commercial, Comptable et Employé. Chaque profil a été associé à des permissions précises selon son rôle fonctionnel. L’administrateur dispose d’un accès total au système et aux paramètres. Le responsable commercial gère les ventes, sans accès aux ressources humaines ni aux paramètres. Le comptable dispose d’un accès au module de facturation et de comptabilité, sans accès aux ventes ni aux données RH. Enfin, l’employé dispose d’un accès très limité, restreint à ses propres informations lorsque cela est autorisé.

Une vérification des permissions attribuées par défaut a été réalisée afin de s’assurer qu’elles restent cohérentes avec le principe du moindre privilège.

Module	**Administrateur**	**Responsable commercial**	**Comptable**	**Employé**
Utilisateurs/ Paramètres	Accès total	Aucun accès	Aucun accès	Aucun accès
Ventes	Accès total	Lecture / écriture	Aucun accès	Aucun accès
Facturation/ Comptabilité	Accès total	Lecture éventuelle	Lecture/ écriture	Aucun accès
Ressources humaines	Accès total	Aucun accès	Aucun accès	Lecture de sa propre fiche uniquement
Logs / Audit	Accès total	Aucun accès	Aucun accès	Aucun accès

2.4 Tests d'accès non autorisés

Afin de valider l'efficacité des restrictions mises en place, plusieurs tests d'accès non autorisés ont été réalisés en se connectant avec chaque profil.

Test 1 — Responsable Commercial : la connexion avec le compte commercial@erp-pme.com confirme que les menus Ressources Humaines, Facturation et Paramètres sont absents de l'interface. La tentative d'accès direct via URL (/odoo/accounting) entraîne une redirection automatique vers la page d'accueil.

Test 2 — Comptable : la connexion avec comptable@erp-pme.com confirme que les menus Ventes et RH sont inaccessibles. L'accès au module Facturation est correctement autorisé.

Test 3 — Employé : la connexion avec employe@erp-pme.com confirme qu'aucun module métier n'est accessible. Seule la fiche personnelle de l'employé est visible.

2.5 Conclusion

La mise en place du RBAC a permis de structurer les accès selon les responsabilités réelles des utilisateurs. Cette organisation constitue une première mesure de sécurité essentielle, car elle réduit les privilèges inutiles, protège les données sensibles de l’ERP et prépare les étapes suivantes du mini-projet, notamment l’analyse des risques et la sécurisation du système.

3 . Analyse des risques et vulnérabilités

3.1 Introduction

Dans cette étape, une analyse des risques a été réalisée afin d’identifier les principales vulnérabilités de l’instance Odoo étudiée. Conformément au sujet du mini-projet, l’analyse s’est concentrée sur les accès excessifs, les failles de configuration, les risques liés aux mots de passe et l’absence de traçabilité. Une matrice de risques a ensuite été établie afin d’évaluer l’impact et la probabilité de chaque menace.

3.2 Risques et vulnérabilités identifiés

L’analyse a mis en évidence plusieurs vulnérabilités importantes. Tout d’abord, l’absence de politique de complexité permet l’utilisation de mots de passe faibles, ce qui augmente le risque de compromission des comptes. Ensuite, certains accès trop larges peuvent exposer des données sensibles, notamment dans les modules financiers et RH. L’absence ou l’insuffisance de mécanismes de traçabilité rend également plus difficile l’identification des actions utilisateurs en cas d’incident. Enfin, plusieurs failles de configuration ont été observées, notamment l’exposition des endpoints XML-RPC et JSON-RPC, l’utilisation du protocole HTTP sans chiffrement, ainsi que l’accessibilité du gestionnaire et du sélecteur de bases de données.

Par ailleurs, une faiblesse de configuration a été relevée au niveau des permissions par défaut d’Odoo. Lorsqu’un utilisateur est créé, certains réglages de permissions hérités automatiquement peuvent accorder des droits trop élevés s’ils ne sont pas vérifiés manuellement. Cette situation constitue une faille de configuration, car elle peut conduire à l’attribution involontaire de privilèges excessifs à un utilisateur mal configuré ou créé sans contrôle suffisant.

3.3 Méthodologie d'analyse des risques

L'analyse des risques a été conduite selon une approche inspirée de la méthode EBIOS Risk Manager (Expression des Besoins et Identification des Objectifs de Sécurité), recommandée par l'ANSSI. Pour chaque risque identifié, nous évaluons deux paramètres sur une échelle de 1 à 5 :

> Impact (I) : gravité des conséquences si le risque se réalise (1 = négligeable, 5 = catastrophique).

- Probabilité (P) : vraisemblance que le risque se réalise (1 = très improbable, 5 = quasi certain).
- Criticité (C) : calculée par le produit C = I × P. Elle détermine la priorité de traitement.

3.4 Analyse des risques les plus importants

Les risques les plus critiques concernent les mots de passe faibles, les accès excessifs et l'absence de traçabilité. Un mot de passe faible facilite les attaques par force brute ou dictionnaire. Des droits d'accès trop larges exposent les données financières et RH à des utilisateurs non autorisés. Enfin, l'absence de logs exploitables rend difficile la détection et l'analyse des incidents de sécurité. En complément, les failles de configuration observées, comme l'exposition des interfaces XML-RPC/JSON-RPC, l'accès au gestionnaire de bases et les permissions par défaut trop permissives, augmentent la surface d'attaque du système.

Cette analyse a permis d'identifier les principales faiblesses de sécurité de l'instance Odoo. Les résultats obtenus justifient la réalisation d'un audit de sécurité structuré et serviront de base à la matrice de risques ainsi qu'aux mesures de sécurisation appliquées dans les parties suivantes.

4. Rapport d'audit de sécurité

4.1 Périmètre de l'audit

L'audit de sécurité a porté sur les principaux composants sensibles de l'ERP Odoo utilisés dans le cadre du mini-projet. L'analyse a concerné en particulier la gestion des utilisateurs et des droits d'accès, les modules Ventes, Facturation, Ressources humaines ainsi que les mécanismes de logs et de traçabilité. Ce périmètre a été défini conformément au sujet du mini-projet, qui impose l'étude des modules liés aux accès, aux données métiers et à l'audit.

4.2 Objectif de l'audit

L'objectif de cet audit est d'identifier les vulnérabilités présentes dans l'instance Odoo étudiée, d'évaluer leur niveau de risque et de proposer des mesures correctives adaptées. Cet audit vise également à vérifier si les accès utilisateurs, les mécanismes de journalisation et les paramètres techniques offrent un niveau de sécurité suffisant pour protéger les données sensibles de l'entreprise.

4.3 Méthodologie d’audit

La démarche d’audit s’est appuyée sur plusieurs étapes. Tout d’abord, une observation de l’instance Odoo a été réalisée afin d’identifier les composants critiques et les modules sensibles. Ensuite, une analyse des comptes utilisateurs et des droits d’accès a été menée pour détecter d’éventuels privilèges excessifs. Des tests de sécurité simples ont ensuite été effectués, notamment sur les mots de passe, l’exposition des interfaces XML-RPC et JSON-RPC, l’accès au gestionnaire de bases de données et la visibilité des logs. Enfin, les résultats obtenus ont été organisés sous forme de constats et serviront de base à la matrice de risques présentée dans la section suivante.

4.4 Constatations et vulnérabilités identifiées

L’audit a mis en évidence plusieurs vulnérabilités importantes. Premièrement, le risque lié aux mots de passe faibles a été identifié, car l’absence de politique de complexité favorise la compromission des comptes. Deuxièmement, des accès trop larges à certains modules peuvent entraîner une exposition non autorisée des données financières et RH. Troisièmement, l’absence ou l’insuffisance de traçabilité rend plus difficile l’identification des actions réalisées par les utilisateurs. Enfin, plusieurs failles de configuration ont été observées, notamment l’exposition des interfaces XML-RPC et JSON-RPC, l’utilisation du protocole HTTP sans chiffrement et l’accessibilité d’interfaces sensibles comme le gestionnaire de bases de données. Ces constats montrent que l’instance étudiée nécessite des mesures de sécurisation supplémentaires.

4.5 Conclusion de l’audit

L’audit de sécurité a permis d’identifier les principales faiblesses de l’instance Odoo et de cibler les zones prioritaires à sécuriser. Les résultats obtenus justifient la mise en place d’une gestion rigoureuse des accès, d’une meilleure traçabilité, d’une protection renforcée des données sensibles et d’une réduction de l’exposition des interfaces techniques. Les risques identifiés sont synthétisés dans la matrice de risques présentée dans la section suivante.

5. Matrice des risques

Afin de synthétiser les vulnérabilités identifiées lors de l'audit, une matrice de risques a été établie. Chaque risque a été évalué selon son impact et sa probabilité, afin de déterminer son niveau de criticité et d'identifier les mesures correctives à mettre en place.

ID	Menace/ Vulnérabilité	Impact	Probabilité	Criticité C=I xP	Mesure corrective
R01	Mots de passe faibles	4	5	20	Politique de mots de passe
R02	Accès excessifs aux modules	5	4	20	RBAC strict +princip
R03	Absence de traçabilité	4	5	20	Activation des logs et audit
R04	HTTP sans HTTPS	4	4	16	Déployer HTTPS en production
R05	Données RH insuffisamment protégées	4	4	16	Record Rules et restrictions par rôle
R06	Gestionnaire de bases exposé	4	3	12	Limiter l'accès à l'administration
R05	Sessions sans expiration automatique	3	4	**12**	session_lifetime dans odoo.conf
R07	Sélecteur de bases visible	3	3	9	Réduire l'exposition de l'interface
R08	Élévation de privilèges non contrôlée	5	2	**10**	Audit groupes + journalisation des changements

6. Sécurisation du système ERP

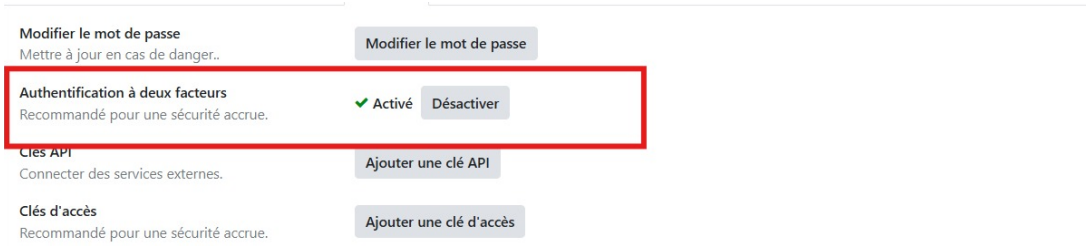
6.1 Introduction

À la suite de l’analyse des risques et de l’audit de sécurité, plusieurs mesures de sécurisation ont été mises en place afin de réduire les vulnérabilités identifiées dans l’instance Odoo. L’objectif de cette étape est de renforcer la sécurité logique et applicative du système en limitant les accès excessifs, en protégeant les données critiques et en améliorant la maîtrise des accès utilisateurs.

6.2 Renforcement de l’authentification

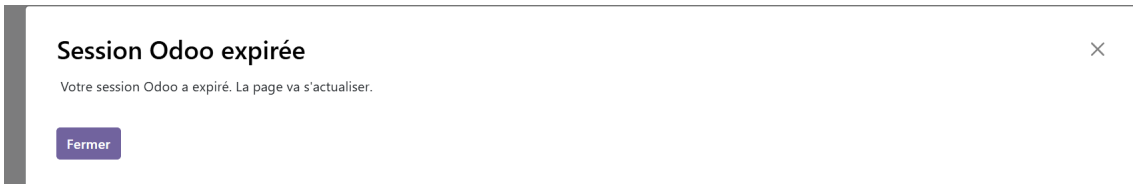
La sécurité des accès utilisateurs a été renforcée par l’application d’une politique de mot de passe minimale. Lors des tests, le système a rejeté les mots de passe trop courts et a imposé une longueur minimale de huit caractères. Cette mesure permet de réduire le risque de compromission des comptes par l’usage de mots de passe faibles.

En complément, un mécanisme d’authentification à deux facteurs (2FA) a été ajouté afin de renforcer la protection des comptes sensibles. Cette mesure introduit un second niveau de vérification lors de l’authentification et limite le risque d’accès non autorisé même en cas de divulgation du mot de passe.



6.3 Gestion des sessions utilisateurs

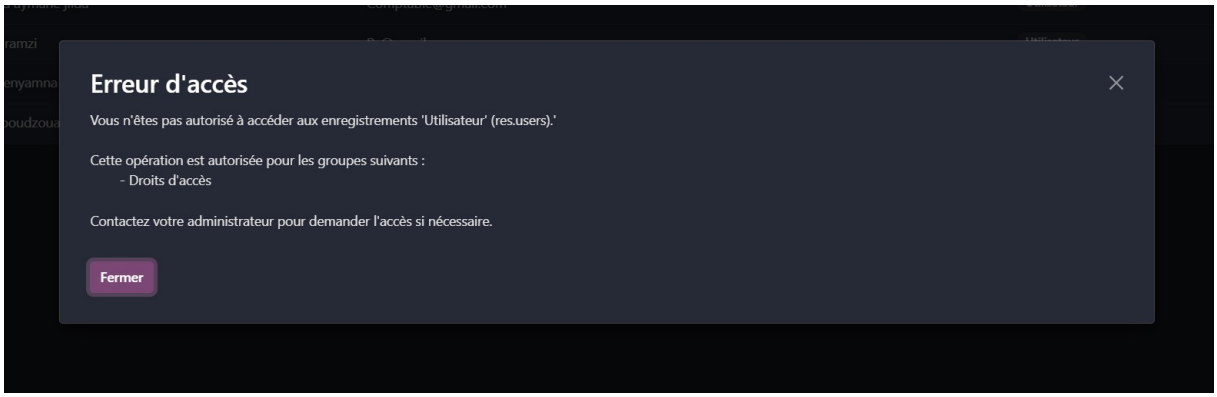
Une durée d’expiration des sessions a été configurée afin d’éviter qu’une session reste active trop longtemps sur un poste partagé ou laissé sans surveillance. Cette mesure impose une nouvelle authentification après un certain délai et améliore le contrôle des accès actifs dans le système.



6.4 Restrictions d’accès par rôle

La principale mesure de sécurité logique appliquée dans l’instance concerne la restriction des accès par rôle. Les permissions ont été organisées selon le modèle RBAC, en attribuant à chaque profil uniquement les droits nécessaires à ses missions. L’administrateur conserve l’accès complet au système, le responsable commercial dispose d’un accès limité aux ventes, le comptable est restreint à la facturation et à la comptabilité, tandis que l’employé dispose d’un accès très réduit.

En complément, les permissions attribuées par défaut dans Odoo ont été vérifiées et ajustées manuellement afin d’éviter l’attribution involontaire de privilèges excessifs à de nouveaux utilisateurs. Cette révision a permis de renforcer l’application du principe du moindre privilège.



6.4 Journalisation et surveillance des actions sensibles

Afin d’améliorer la sécurité et la visibilité sur les opérations réalisées dans l’instance, un module complémentaire de sécurité et d’audit a été ajouté. Ce module permet de journaliser

certaines actions importantes, de suivre les créations, modifications et suppressions, et de générer des alertes en cas d'activité jugée sensible ou anormale.

Cette journalisation joue un rôle important dans la sécurité du système, car elle améliore la visibilité sur les actions effectuées et facilite l'analyse d'éventuels incidents. Elle constitue également une base utile pour l'audit et la traçabilité présentés dans la partie suivante.

6.5 Sécurisation des données critiques

Les données les plus sensibles du système concernent principalement les informations financières et les données liées aux ressources humaines. Afin de mieux protéger ces données, l'accès aux modèles critiques a été limité selon les rôles des utilisateurs.

Les modules comptables ont été réservés aux profils autorisés, tandis que les informations RH ont été restreintes aux utilisateurs concernés. Cette mesure permet de réduire les risques d'accès non autorisé, de modification non justifiée et d'exposition des données sensibles.

6.6 Détection et blocage des activités anormales

Des mécanismes d'alerte ont été mis en place pour signaler certaines activités anormales. Une règle de sécurité a notamment été créée pour détecter les modifications de comptes bancaires sur les contacts. Lorsqu'une telle modification est réalisée, une alerte est générée afin de signaler immédiatement l'opération.

Le système a également permis de bloquer certaines actions jugées suspectes, comme des suppressions répétées de contacts dans un intervalle réduit. Ce comportement a été détecté automatiquement, l'opération a été refusée et un message d'alerte a été affiché. Cette logique ajoute une couche de sécurité proactive à l'instance Odoo.

6.7 Sauvegarde automatique des données

Afin de réduire le risque de perte de données, une procédure de sauvegarde a été mise en place. Une tâche planifiée a été configurée pour exécuter automatiquement un script de sauvegarde à intervalle régulier. Cette mesure améliore la disponibilité et la résilience du système en facilitant la récupération des données en cas d'incident, d'erreur humaine ou de défaillance technique.

6.9 Mesures complémentaires recommandées

Certaines failles observées relèvent de la configuration technique et de l'infrastructure de déploiement. Il s'agit notamment de l'exposition des endpoints XML-RPC et JSON-RPC, de l'utilisation du protocole HTTP sans chiffrement et de l'accessibilité du gestionnaire de bases de données.

Pour un environnement réel, il est recommandé de protéger l'instance Odoo par HTTPS, de limiter l'exposition des interfaces techniques au réseau de confiance, de réduire l'accès aux fonctions d'administration sensibles et de renforcer la sécurité globale du déploiement.

Les mesures de sécurisation appliquées dans l'instance Odoo ont permis de renforcer plusieurs aspects essentiels de la sécurité : l'authentification, la gestion des sessions, la limitation des accès, la protection des données critiques, la journalisation des actions sensibles, la détection d'activités anormales et la sauvegarde automatique. Ces actions constituent une réponse directe aux risques identifiés lors de l'audit et améliorent sensiblement le niveau global de sécurité du système.

7. Audit et traçabilité

7.1 Introduction

Dans le cadre de ce mini-projet, une phase d'audit et de traçabilité a été menée afin de renforcer la visibilité sur les actions réalisées dans l'ERP Odoo et de vérifier l'efficacité des mesures de sécurité mises en place. Cette étape répond directement aux objectifs du projet, qui demandent l'activation des logs, le suivi des actions utilisateurs, la détection d'actions anormales et l'analyse des traces.

7.2 Activation des logs et sources de traçabilité

Dans l'environnement Odoo Enterprise Online, l'accès direct au fichier de configuration serveur n'était pas disponible depuis l'interface d'administration. La traçabilité technique a donc été abordée à travers les mécanismes mis à disposition par la plateforme, notamment la consultation des journaux administratifs via le Database Manager, avec l'option permettant de visualiser les activités administratives.

En parallèle, dans l’environnement Community, la traçabilité a été renforcée par l’installation d’un module complémentaire de sécurité et d’audit. Ce module a permis d’ajouter une journalisation plus détaillée sur certains modèles sensibles, notamment les contacts, avec la possibilité d’enregistrer les créations, modifications, suppressions et exports.

7.3 Suivi des actions utilisateurs

Le suivi des actions utilisateurs a été réalisé à partir de plusieurs niveaux complémentaires. Le premier concerne la gestion des comptes et des droits d’accès, accessible à travers les utilisateurs et leurs onglets de permissions. Le second concerne la traçabilité fonctionnelle dans l’interface, à travers le chatter, les activités planifiées et les traces visibles après certaines opérations sensibles.

Après installation du module d’audit, une règle intitulée **Audit Complet des Contacts** a été configurée sur le modèle Contact. Cette règle a été paramétrée pour enregistrer les créations, les écritures, les suppressions et les exports, avec journalisation complète et conservation des valeurs au moment de la suppression. Cette configuration a permis d’obtenir une traçabilité plus fine sur les opérations effectuées sur les contacts.

7.4 Détection d’actions anormales

La détection d’actions anormales a été abordée à travers plusieurs scénarios simples, réalisés sans outils offensifs. Des essais d’accès non autorisés ont permis de vérifier que les droits étaient bien limités selon les rôles définis. Lorsque les permissions étaient correctement configurées, les utilisateurs ne voyaient pas certains menus ou recevaient un refus d’accès.

En complément, les mécanismes ajoutés par le module de sécurité ont permis de détecter des comportements jugés sensibles ou suspects. Une règle d’alerte a notamment été créée pour surveiller les modifications des comptes bancaires sur les contacts. Lorsqu’une modification a été réalisée, une activité planifiée d’alerte a été automatiquement générée à destination de l’administrateur, avec un message signalant que le RIB avait été modifié et devait être vérifié rapidement.

Le système a également permis de détecter un nombre anormal de suppressions de contacts dans un intervalle réduit. Dans ce cas, l’action a été bloquée et un message d’erreur a été affiché, indiquant qu’une activité anormale avait été détectée et signalée.

7.5 Analyse des traces

L’analyse des traces a consisté à examiner les informations disponibles après la réalisation d’actions de test, telles que la connexion avec différents profils, la modification d’informations sensibles, la suppression répétée d’enregistrements et la génération d’alertes automatiques.

Les éléments observés ont permis de distinguer les actions légitimes des actions bloquées, puis d’évaluer si la plateforme fournissait un niveau de preuve et de suivi exploitable dans un contexte d’audit. Les activités planifiées, les traces visibles dans l’interface et les journaux administratifs ont montré que les mécanismes de traçabilité sont essentiels pour vérifier la cohérence des permissions et repérer les anomalies.

7.6 Approche SOC simplifiée

L’ensemble de ces mécanismes permet de mettre en œuvre une approche SOC simplifiée. Dans ce cadre, les événements sensibles sont observés, enregistrés, puis analysés afin de détecter les comportements suspects. Sans constituer un centre opérationnel de sécurité complet, cette approche permet déjà de combiner surveillance, journalisation, détection et réaction sur des événements critiques, ce qui répond au périmètre du mini-projet.

Au terme de cette phase, nous constatons que la combinaison des mécanismes natifs d’Odoo Enterprise Online et des fonctionnalités complémentaires ajoutées dans l’environnement Community a permis d’obtenir une traçabilité plus complète des actions utilisateurs. L’activation des logs, la création de règles d’audit, la génération d’alertes et le blocage de certaines activités anormales ont renforcé la capacité du système à détecter, suivre et analyser les événements sensibles. Cette étape confirme l’importance de la traçabilité dans la sécurité globale d’un ERP.

8. Améliorations logicielles

8.1 Introduction

Au-delà des mesures de sécurisation et des mécanismes natifs de traçabilité disponibles dans Odoo, une amélioration logicielle a été mise en place afin de renforcer le contrôle de sécurité du système. Cette amélioration répond directement aux faiblesses identifiées lors de l’analyse

des risques, notamment le besoin d’une meilleure détection des actions sensibles, d’une journalisation plus exploitable et d’un mécanisme d’alerte en cas de comportement anormal.

L’objectif de cette partie est de présenter l’extension développée, son fonctionnement général et son apport dans la sécurisation globale de l’ERP. Le travail réalisé ne se limite donc pas à la configuration d’Odoo, mais inclut également une logique d’amélioration du système par ajout de fonctionnalités orientées sécurité et audit.

8.2 Objectif de l’amélioration

Le mini-module développé dans Odoo a pour objectif principal de mettre en place un mécanisme de contrôle de sécurité au sein du système ERP. Il permet de surveiller les actions sensibles réalisées par les utilisateurs, notamment les opérations de création, de modification ou de suppression sur des données importantes telles que les contacts, les employés ou les factures.

Cette amélioration vise à répondre à plusieurs besoins concrets : renforcer la visibilité sur les actions utilisateurs, améliorer la traçabilité des événements sensibles, détecter plus rapidement les anomalies et assister l’administrateur dans le suivi des incidents de sécurité. Elle s’inscrit ainsi dans une logique d’amélioration continue de la sécurité applicative.

8.3 Présentation du module développé

Dans le cadre du projet, une extension spécifique nommée **Extension Sécurité Audit** a été ajoutée à l’instance Odoo. Cette extension complète les mécanismes de base de la plateforme en introduisant une couche de journalisation renforcée et de détection d’activités anormales.

Le module permet d’enregistrer les actions sensibles dans un journal de sécurité contenant plusieurs informations utiles, telles que l’utilisateur concerné, le type d’action, le modèle ciblé, la date et les détails de l’opération. Cette journalisation assure une meilleure traçabilité et facilite les opérations d’audit. En complément, le module prend en charge la génération d’alertes lorsqu’une activité est jugée anormale ou critique. Les événements détectés peuvent être qualifiés selon un niveau de gravité et un statut, ce qui permet d’améliorer le suivi des incidents et la réactivité de l’administrateur.

8.4 Fonctionnement général

Le fonctionnement du module repose sur la surveillance de certaines opérations effectuées sur des modèles sensibles. Lorsqu'une action répond à une règle définie comme importante ou suspecte, le système peut enregistrer l'événement, générer une alerte, ou bloquer l'opération selon le scénario retenu.

Dans notre cas, ce mécanisme a notamment été utilisé pour surveiller les modifications de comptes bancaires sur les contacts. Une règle d'alerte a été créée afin que toute modification du RIB déclenche automatiquement une activité planifiée destinée à l'administrateur. Cette approche permet une réaction rapide lorsqu'une donnée critique est modifiée. Le système a également permis de bloquer certaines activités considérées comme anormales, comme des suppressions répétées d'enregistrements dans un intervalle réduit. Cette combinaison entre journalisation, alerte et blocage montre que l'amélioration logicielle ne se limite pas à observer les événements, mais participe activement à la réduction du risque.

8.5 Apport du module à la sécurité

L'ajout de cette extension améliore plusieurs dimensions de la sécurité du système. D'abord, il renforce la traçabilité des opérations en conservant des informations détaillées sur les actions sensibles. Ensuite, il améliore la détection des anomalies en introduisant des mécanismes d'alerte sur des comportements jugés critiques. Enfin, il apporte une capacité de réaction plus rapide grâce au signalement automatique de certains événements et au suivi des alertes.

Le module représente donc un complément utile aux fonctions natives d'Odoo. Il permet de passer d'une logique de simple observation à une logique plus proactive, où certaines actions sont surveillées, classées, signalées et éventuellement bloquées. Cette amélioration apporte une valeur ajoutée directe en matière de sécurité, de gouvernance des accès et de contrôle des opérations sensibles.

8.6 Suivi des incidents et gestion des alertes

Le module ne se contente pas de détecter les événements ; il intègre également une logique de suivi des incidents de sécurité. Les alertes peuvent être marquées selon leur gravité et leur statut, ce qui permet de distinguer les événements normaux des événements suspects. Un indicateur de traitement permet aussi de savoir si l'incident a déjà été pris en charge ou non.

Cette fonctionnalité facilite le travail de l'administrateur, qui peut analyser les événements, prioriser les alertes et suivre leur traitement dans le temps. En ce sens, l'extension développée se rapproche d'un outil de supervision simplifié, adapté au cadre du mini-projet et cohérent avec l'approche d'audit et de traçabilité mise en place.

8.7 Intérêt en maintenabilité et en évolutivité

Sur le plan de l'ingénierie logicielle, cette amélioration présente également un intérêt en termes de maintenabilité et d'évolutivité. En centralisant la logique de surveillance dans un module dédié, le système devient plus lisible et plus facile à faire évoluer. De nouvelles règles d'alerte peuvent être ajoutées progressivement sur d'autres modèles ou d'autres types d'actions sensibles, selon les besoins futurs.

Cette approche modulaire est cohérente avec l'architecture d'Odoo et permet d'enrichir le système sans modifier directement le noyau de l'application. Elle constitue donc une amélioration logicielle pertinente, à la fois sur le plan fonctionnel et sur le plan de la sécurité.

8.8 Conclusion

L'amélioration logicielle apportée au système Odoo a permis d'ajouter une couche de sécurité proactive reposant sur la journalisation renforcée, la détection d'anomalies, la génération d'alertes et le suivi des incidents. Cette extension complète efficacement les mécanismes natifs de la plateforme et répond directement aux besoins identifiés lors de l'analyse des risques et de l'audit de sécurité.

Elle montre également que la sécurisation d'un ERP ne repose pas uniquement sur les droits d'accès ou la configuration, mais peut être renforcée par des développements ciblés capables d'améliorer la surveillance, la réactivité et la maîtrise des opérations sensibles.

9. Tests et validation

9.1 Objectif des tests

L'objectif de cette phase est de vérifier l'efficacité des mesures de sécurité mises en place dans le système Odoo, ainsi que leur bon fonctionnement dans des situations réelles. Les tests permettent de valider que les mécanismes de protection empêchent les actions non autorisées, détectent les comportements anormaux et assurent la traçabilité des opérations.

9.2 Tests de contrôle d'accès (RBAC)

Des tests ont été réalisés afin de vérifier que chaque utilisateur dispose uniquement des permissions nécessaires à son rôle.

- Tentative d'accès aux modules comptables par un utilisateur non autorisé → Accès refusé
- Tentative de modification des données RH par un utilisateur simple → Accès bloqué
- Vérification des permissions sur les modèles sensibles (account.move, res.users) → Restrictions appliquées correctement

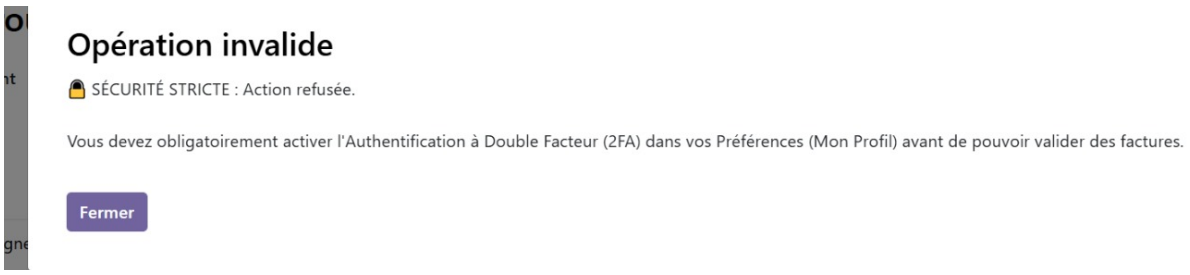
Résultat :
Le principe du moindre privilège est respecté et les accès sont correctement contrôlés.

9.3 Tests d'authentification et sessions

Les mécanismes d'authentification ont été testés afin de garantir la sécurité des comptes utilisateurs.

- Test de mot de passe faible → Refusé (politique de sécurité appliquée)
- Activation de l'authentification à deux facteurs → Connexion sécurisée validée
- Test d'expiration de session → Déconnexion automatique après inactivité

Résultat :
Le système protège efficacement les comptes contre les accès non autorisés.

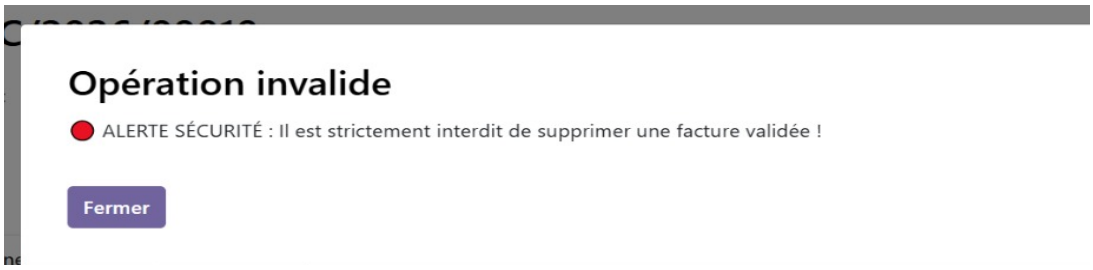


9.4 Tests de détection d'anomalies

Des scénarios d'attaques ou de comportements suspects ont été simulés.

- Suppression répétée de contacts → Blocage automatique + message d'erreur
- Modification du RIB d'un contact → Alerte générée et envoyée à l'administrateur
- Actions inhabituelles sur données sensibles → Détection et journalisation (export massive des données)

Résultat :
Le système détecte et bloque les comportements anormaux en temps réel.



9.5 Tests de journalisation et traçabilité

Les fonctionnalités d'audit ont été vérifiées pour assurer le suivi des actions utilisateurs.

- Création, modification et suppression → Enregistrées dans les logs
- Identification de l'utilisateur, date et type d'action → Correctement tracés
- Consultation des journaux → Accessible pour analyse

Résultat:

Une traçabilité complète des actions est assurée, facilitant les audits de sécurité.

Nom	Modèle	Type	Enregistrer le...	Enregistrer le...	Enregistrer le...	Enregistrer le...	Log Exports	État
Audit Complet des Contacts	Contact	Journaux complet	☐	☑	☑	☑	☑	Confirmed
Audit Sécurité Ventes	Commande client	Journaux complet	☐	☑	☑	☑	☑	Confirmed
RH / Salaires	Employé	Journaux complet	☑	☐	☑	☐	☑	Confirmed
Configuration	Utilisateur	Journaux complet	☐	☑	☑	☑	☑	Confirmed

9.6 Tests de sauvegarde

Les mécanismes de sauvegarde ont été testés pour garantir la disponibilité des données.

- Exécution du script de sauvegarde automatique → Succès
- Vérification des fichiers générés → Valides et exploitables
- Planification quotidienne → Fonctionnelle

Résultat :

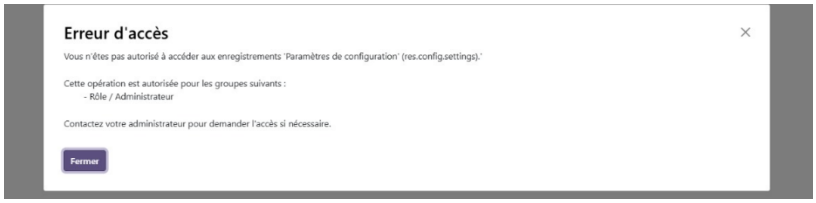
Les données peuvent être restaurées en cas d'incident, assurant la continuité du service.

9.7 Validation globale

L'ensemble des tests réalisés confirme que :

- Les accès sont correctement sécurisés
- Les données sensibles sont protégées
- Les actions utilisateurs sont tracées
- Les comportements anormaux sont détectés et bloqués
- Les données sont sauvegardées de manière fiable

En Conclusion le système Odoo a été significativement renforcé en termes de sécurité, de contrôle et de traçabilité.



10. Conclusion

Ce projet nous a permis de mettre en œuvre une démarche complète d'audit, de sécurisation et d'amélioration d'un système ERP Odoo. En travaillant sur la version Community, nous avons pu constater concrètement les limitations de cette édition en matière de sécurité avancée, tout en développant des solutions compensatoires documentées et opérationnelles.

La comparaison systématique avec Odoo Enterprise, intégrée section par section dans ce rapport, permet d'identifier clairement les fonctionnalités qui apporteraient une valeur ajoutée significative en environnement professionnel : authentification forte (2FA), journalisation centralisée, gestion avancée des sessions et support éditeur pour les correctifs.

Les mesures mises en oeuvre RBAC strict avec 4 profils, politique de mots de passe, logs de traçabilité, mini-module Python d'alertes automatiques et constituent une base solide qui répond aux exigences initiales du projet et réduit significativement les risques identifiés dans la matrice.

11. Tableau de répartition des tâches

#	Membre	Rôle	Tâches réalisées
c	Walid Hamroud	Architecture, contexte & présentation	• Analyse et doc. de l'architecture Odoo (schéma 3 couches) • Rédaction du contexte et des objectifs du projet • Préparation et animation de la présentation orale (10 min)
2	Norhane Ramzi	Sécurité des accès	• Création des 4 profils utilisateurs dans Odoo • Configuration RBAC (groupes, droits d'accès) • Application du principe du moindre privilège • Rédaction de la matrice des droits d'accès
3	Mehdi Boudzouaou	Modules, backup & logs	• Création et installation des modules Odoo Community • Configuration des sauvegardes automatiques (pg_dump + cron) • Activation et configuration des logs système

			• Tests de fonctionnement des modules et sauvegardes(avec miloudy)
4	Mohamed Aymane Jlida	Modules, backup & logs	• Création et config. des modules Odoo (avec Ramzi ,Mehdi) • Script de sauvegarde et planification (avec Mehdi) • Configuration et activation des logs Odoo (avec Mehdi) • Vérification de l'intégration modules + logs
5	Zakariya Benyamna	Traçabilité & logs	• Activation du Chatter et tracking des champs sensibles • Analyse des logs . • Définition des indicateurs de détection d'anomalies • Création des diagrammes UML et schémas du projet
6	Zakariya Miloudy	Tests & diagrammes	• Réalisation des tests fonctionnels T01 à T07 • Réalisation des tests de sécurité S01 à S06 • Simulation des scénarios d'attaque A, B et C • Création des diagrammes UML et schémas du projet
7	Tous les membres	Rapport d'audit & rapport final	• Rédaction du rapport d'audit de sécurité (chacun sa section) • Rédaction du rapport final complet (10–15 pages) • Relecture croisée et corrections finales • Mise en page et remise du rapport final

Guide de connexion

Email	Mots de passe
Employe@gmail.com	admin

Rc@gmail.com	**admin**
Comptable@gmail.com	**Admin**
zakaria.benyamna.estn24@ump.ac.ma	**ilcs 0009.**

Lien d'odoo : https://edu-multiservices2.odoo.com/

Version Communauté :

Email	**Mots de passe**
employe@gmail.com	**Password123**
commerce@gmail.com	**Password123**
comptable@gmail.com	**admin**
elmahdi.boudzouaou.estn24@ump.ac.ma	**ilcs 0009.**